Phụ lục Ngắn Báo cáo Tiến độ Lần 1: Kết quả Thực hiện Nhiệm vụ Ban đầu (simple_semgrepAI -> OpenGrep + Local Qwen)

> **Ghi chú tài liệu:** Đây là bản phụ lục rút gọn (độ dài mục tiêu 2-3 trang khi xuất ra định dạng văn bản/PDF tại `v2/docs/ADVISOR_ORIGINAL_TASK_APPENDIX_SHORT_20261111.pdf`). Bản phụ lục kỹ thuật đầy đủ kèm toàn bộ mã băm SHA-256 được lưu tại `v2/docs/ADVISOR_ORIGINAL_TASK_APPENDIX_20261111.md`, và bảng đối chứng A/B chính thức tại `v2/evaluation/ADVISOR_PAIRED_PILOT_20261111.md` (`.csv`).

- **Repository & Nhánh:** `https://github.com/TuanKhoa1201/22025523-NTK-UET-Thesis/tree/v2/integration-pilot`
- **Các nhánh thành phần đã hợp nhất (`git merge --no-ff` trên nền `f92d5f915c9dc9a34604efa29820e662fd7b616b`):** `v2/codex-core` (`c36bc120de2922413c53c26e42648b184ac3e5c7`), `v2/antigravity-review` (`f25ce45a812a94198f09db7b296a2caf52174ca3`), `v2/javis-benchmark` (`43e1d648402704b9bc42698e62175805d720f7ff`).

1. Môi trường Thực nghiệm & Phạm vi Nhiệm vụ Gốc

Hạng mục	Cấu hình / Trạng thái đã xác minh trên máy chủ `ADMIN-PC`
Hệ điều hành & Python	Windows 11 Pro (`10.0.26200`, Python `3.12.10`) + WSL2 `Ubuntu-IRIS` (Python `3.10.22`, OpenJDK `17.0.20.1`)
Công cụ SAST	`OpenGrep 1.25.0` chạy trong WSL2 (`/usr/local/bin/opengrep`) + cầu nối Windows `opengrep.cmd`
Hạ tầng LLM cục bộ	`Ollama 0.40.7` (`127.0.0.1:11434`, `OLLAMA_NOPRUNE=true`) trên GPU **`NVIDIA RTX 4060 Ti 16 GB`** (`100% GPU`)
Mô hình đã chạy thật	**`qwen3.5:9b-q4_K_M`** (mô hình chính, `manifest SHA-256: 7dd7bb31...`, `5.63 GB` + `mmproj 921.7 MB`) và **`qwen3:8b`**
Nguồn Upstream	`hardw00t/simple_semgrepAI` (`commit 2c79a58a16d11e9dea3723e30d2a7faffba7bdc9`, giấy phép `MIT`)

Phân định rõ phạm vi kế thừa và sửa đổi (`v2/baseline/opengrep.patch` vs. gói tham khảo `opengrep-triage.zip` của giảng viên):

1. **Scanner/CLI tinh gọn (`v2/baseline/fork/semgrepai/`) đã chạy thật (`PASS`):** Chuyển từ `semgrep scan --config=auto` sang `opengrep scan` cục bộ với `--json`/`--sarif`, `--dataflow-traces`, `--no-git-ignore`, `--disable-version-check`, `--jobs 1`; sinh biên lai quét `scan-manifest.json` (`ntk-scan-capture-1`, kiểm chứng qua `scan_receipt.py`); sửa lỗi mất vết dữ liệu của upstream bằng cách đọc đúng `result['extra']['dataflow_trace']` (`taint_source`, `intermediate_vars`, `taint_sink`) và giữ trạng thái mặc định `REVIEW`.
2. **Toàn bộ ứng dụng `simple_semgrepAI` upstream đầy đủ chưa chạy thành công (`PENDING / NOT DONE`):** Các thành phần FastAPI web, ChromaDB (RAG) và LangChain cloud LLM của upstream bị lược bỏ do xung đột phụ thuộc và để bảo đảm mã nguồn chỉ xử lý cục bộ (`127.0.0.1`).
3. **Đối chiếu với `opengrep-triage.zip` của thầy:** Đã kiểm thử cô lập ngoài Git worktree (`15/15 pytest PASS`, `git apply --check` cho patch 4 file của thầy đạt `PASS`). Bản vá của đồ án (`v2/baseline/opengrep.patch`, khớp khứ hồi `4` file fork `scanner.py`, `config.py`, `cli.py`, `scan_manifest.py` qua `verify_patch.py`) giữ nguyên cấu trúc ATD `CliLoc` để kiểm chứng dòng/cột/byte offset/SHA-256 thay vì làm phẳng (`flatten`) như bản tham khảo. Tệp `Bo_ma_OpenGrep_Java_Qwen.zip` nhắc trong PDF 5 trang không có trong thư mục nguồn (**NOT PROVIDED**).

2. Lệnh Chạy Tối thiểu Đã Xác minh trên Máy chủ (`exit_code = 0`)

Chạy từ PowerShell tại thư mục gốc `C:\Users\Admin\ntk-thesis-v2\integration-pilot` (sử dụng thư mục đầu ra mới ngoài Git để không ghi đè bằng chứng đã lưu):

```
Set-Location "C:\Users\Admin\ntk-thesis-v2\integration-pilot"
$env:PATH = "C:\Users\Admin\ntk-thesis-v2\tools\opengrep\v1.25.0;$env:PATH"

# 1. Kiểm chứng chính sách kho mã, patch upstream (4 fork files), toàn bộ 162 bài Unit Test và 11 cổng tích hợp -> exit_code = 0
python scripts/verify-repository.py
python v2/baseline/verify_patch.py
python -m pytest v2/baseline/tests v2/triage/tests v2/evaluation/tests v2/demo/tests -q
python v2/scripts/run_v2_quality_gate.py

# 2. Chạy tái lập chế độ REPLAY (dùng bằng chứng Qwen3.5-9B đã khóa, kiểm chứng scan_sha256 + demo queue/freshness) -> exit_code = 0
$ReplayDir = "C:\Users\Admin\ntk-thesis-v2\evidence\repro_replay_$(Get-Date -Format 'yyyyMMdd_HHmmss')"
powershell.exe -NoProfile -ExecutionPolicy Bypass -File "v2\demo\reproduce_integration_pilot.ps1" -Mode REPLAY -EvidenceRoot $ReplayDir
```

```
# 3. Chạy tái lập chế độ LIVE (quét mới OpenGrep 1.25.0 + scan-manifest.json + gọi thật Ollama Qwen3.5:9b-q4_K_M) -> exit_code = 0
$LiveDir = "C:\Users\Admin\ntk-thesis-v2\evidence\repro_live_$(Get-Date -Format 'yyyyMMdd_HHmmss')"
powershell.exe -NoProfile -ExecutionPolicy Bypass -File "v2\demo\reproduce_integration_pilot.ps1" -Mode LIVE -SkipHeavyDemos -Evide
nceRoot $LiveDir
```

3. Kết quả Thực nghiệm Sơ bộ trên Mã Java Tổng hợp (`SYNTHETIC SMOKE PILOT, n = 3`)

Trên tệp `v2/evaluation/smoke_evidence/SmokeVulnSample.java` (`2 TP`, `1 FP`, `SHA-256: 090c9349...`), bộ quy tắc `v2/baseline/rules/java.yml` sinh **3 cảnh báo**. Đã xác minh trên cả bản lưu lịch sử **`REPLAY`** (`v2/demo/triage_qwen35_9b_smoke_m1_assessments.jsonl`, `scan_sha256: 005863f2...`, `SHA-256: dc73a82c...`) và lượt chạy **`LIVE` mới có gắn `scan-manifest.json`** (`evidence/repro_live_verified_20261111_c36_f25`, `scan_sha256: 4d628a21...`, `manifest_sha256: 77da8733...`, `assessments.jsonl SHA-256: 939f0949...`):

Finding / CWE / Vị trí	Nhãn Fixture (`SYNTHETIC`)	Dataflow Trace (`Source -> Sink`)	Kết quả `qwen3.5:9b-q4_K_M` & Kiểm chứng trích dẫn	Độ trễ `REPLAY` / `LIVE` & Hàng đợi
#0 (`5c3fa49a...` / `35a3a20e...`) `CWE-89` - Dòng 28 (`unsafeSqlLookup`)	`TRUE_POSITIVE`	`getParameter("username")` (d.25) -> `query` (d.26) -> `executeQuery(query)` (d.28)	`SUPPORTED` (`KEEP_TP`) `citation_check = MATCHED` (dòng 25-28)	`19719.0 ms` (`334` tok) / `8063.0 ms` (`347` tok), `OPEN`
#1 (`76501a37...` / `651f41b0...`) `CWE-22` - Dòng 33 (`unsafeFileRead`)	`TRUE_POSITIVE`	`getParameter("report")` (d.32) -> `new File("/var/app/reports/" + rawReportName)` (d.33)	`SUPPORTED` (`KEEP_TP`) `citation_check = MATCHED` (dòng 32-33)	`10953.0 ms` (`458` tok) / `10406.0 ms` (`441` tok), `OPEN`
#2 (`3252602f...` / `0dbe51f1...`) `CWE-22` - Dòng 47 (`safeFileRead`)	`FALSE_POSITIVE` (có `FilenameUtils.getName` ở d.46)	`getParameter("report")` (d.45) -> `cleanName` (d.46) -> `new File(... + cleanName)` (d.47)	**`SUPPORTED` (Nhận định sai FP thành TP)** `citation_check = MATCHED` (dòng 45-47)	`10078.0 ms` (`409` tok) / `9969.0 ms` (`412` tok), `OPEN`

Tổng hợp đối chứng A/B (`n = 3, SYNTHETIC SMOKE PILOT`):

- **Nhánh A (OpenGrep 1.25.0 đơn lẻ):** Giữ cả `3/3` cảnh báo (`2 TP`, `1 FP`).
- **Nhánh B (OpenGrep 1.25.0 + `qwen3.5:9b-q4_K_M` ở cả `REPLAY` và `LIVE`):**
- **FP được đề xuất loại đúng:** **`0/1 (0.0%)`** (mô hình nhận ra `FilenameUtils.getName` ở dòng 46 nhưng vẫn xếp `SUPPORTED` vì yêu cầu thêm whitelist tên tệp).
- **TP bị đề xuất loại nhầm:** **`0/2 (0.0%)`** (cả 2 lỗ hổng thật đều được giữ lại chính xác).
- **Tỷ lệ trích dẫn khớp mã nguồn & SHA-256:** **`3/3 (100.0%)`** (`REVIEW / UNDETERMINED = 0/3`, cải thiện rõ rệt so với `1/3 MATCHED` ở `qwen3:8b`).
- **Khác biệt `scan_provenance` (`REPLAY` vs `LIVE`):** Bản `REPLAY` lịch sử chưa gắn `scan-manifest.json` (`HISTORICAL_UNBUNDLED`) nên bị hạ về `3/3 REVIEW` khi bật cờ nghiêm ngặt `--require-scan-provenance`; bản `LIVE` mới có `scan-manifest.json` hợp lệ (`source_capture_verified = true`, `VERIFIED_CAPTURE`) nên giữ nguyên `3/3 KEEP_TP` qua cả `export_pilot.py` và `score_pilot.py --require-scan-provenance`.
- **Số cảnh báo tự động bị loại bỏ:** **`0/3 (0.0%)`** (100% giữ `state = OPEN`, bắt buộc con người xác nhận).
- **Độ trễ trung bình:** **`13583.333 ms` (`REPLAY`, có cold-load)** và **`9479.333 ms` (`LIVE`, warm GPU)**; trạng thái giao thức runtime: `OLLAMA_REPORTED_UNATTESTED` (`independently_verified_model_runtime = false`).

4. Kết quả Kiểm duyệt Liên hoàn & Hạn chế Kỹ thuật Còn Tồn tại

1. **Demo quy trình kiểm duyệt liên hoàn sau merge (`P0.3 - HOÀN THÀNH 100% PASS`):**
   - `python -m v2.triage.demo_queue` (`exit_code = 0`), `demo_freshness.py` (`exit_code = 0`) và kịch bản CLI 7 bước trên bản sao `SmokeVulnSample.java` đã xác nhận đầy đủ:
   - `decide ... confirm-false --actor SCRIPTED-DEMO` (`exit_code = 0`) -> **ẩn cảnh báo `CONFIRMED_FALSE` khỏi hàng đợi `queue` mặc định** (`1 -> 0` trong `demo_queue.py`; `3 -> 2` trên `SmokeVulnSample.java`).
   - `queue --all` vẫn bảo toàn toàn bộ bản ghi trong SQLite (`1` và `3`); `show` trả về `state = "CONFIRMED_FALSE"`; `history` lưu đầy đủ `actor`, `timestamp`, `action`, `reason`, `source_version` và `evidence_sha256`.
   - `decide ... reopen --actor SCRIPTED-DEMO` (`exit_code = 0`) -> cảnh báo xuất hiện lại trong `queue` mặc định (`0 -> 1` và `2 -> 3`).

- Sửa bản sao tệp Java sau lượt quét làm đổi SHA-256 -> thao tác `confirm-false` bị **từ chối với** `exit_code = 2` (`source hash mismatch; rescan required`), lịch sử `history` giữ nguyên không bị ghi đè.
- **Xử lý tương thích Windows/WSL2, Git & Cổng Chất lượng (`162/162 PASS`):**
- Binary `opengrep_windows_x86.exe` bị Windows 11 Smart App Control chặn (`Error 4551`), đã giải quyết qua `/usr/local/bin/opengrep` trong WSL2 `Ubuntu-IRIS` kết hợp cầu nối `opengrep.cmd` và cờ `--path-map`.
- Các tệp snapshot upstream trong `v2/baseline/upstream/` **và** `v2/baseline/opengrep.patch` **được bảo toàn nguyên vẹn từng byte bằng thuộc tính** `-text` **trong** `v2/baseline/.gitattributes`**, giúp** `verify_patch.py` **và toàn bộ** `162/162` bài test (`27` M1 + `70` M2/M3 + `28` Evaluation + `37` Quality Gate)** đạt `PASS`.
- Token GitHub trên máy chủ hiện thiếu scope `workflow`, nên file `.github/workflows/v2-quality-gate.yml` đang ở trạng thái **BLOCKED** khi push lên GitHub Cloud Actions; cổng kiểm định 11 bước được đặt tại `v2/workflows/v2-quality-gate.yml` + `v2/scripts/run_v2_quality_gate.py` và tự động chạy qua Git `pre-push` hook trên worktree tích hợp.
- **Các hạng mục chưa thực hiện (`NOT DONE`):**
- Chưa chạy thành công toàn bộ ứng dụng web/RAG/cloud `simple_semgrepAI` upstream (chỉ kế thừa và chuẩn hóa phần scanner/CLI).
- Chưa thực hiện quét dự án Java thực tế (`P0.4`) và chưa có kết quả benchmark độc lập trên tập 30-60 cảnh báo / OWASP Benchmark.